INCIDENT RESPONSE & FORENSIC REPORT

Supply-Chain Attack Chain Reconstruction & Token Recovery | Ref: BMH-IR-2026-1013

Incident Ref:	BMH-IR-2026-1013	**Target Host:**	BLACKMERE\mvale
Date/Time:	2026-10-13 18:02 UTC	**Vector:**	npm Supply-Chain
Severity:	**CRITICAL**	**Status:**	Mitigated & Recovered
Target Repository:	fogline-showctl	**Recovered Token:**	**forensic{...}**

1. Executive Summary

> **RECOVERED SHOWVAULT ROOT TOKEN (FLAG):**
> `forensic{8568b8444a7ac5335005c821}`

During the peak operational week of Blackmere Haunted Attraction Park, a critical supply-chain security breach occurred on the primary show-control workstation (BLACKMERE\mvale). A routine 'npm install' command pulled a trojanized dependency—pale-hash-utils@2.1.0—from the internal mirror (npm-mirror.blackmere.lan:4873).

The malicious package executed a sophisticated multi-stage payload that used steganographic font file payload delivery, corporate proxy traversal, dynamic DNS-based key exchange, and custom Base32 data exfiltration over DNS A queries. Forensic reconstruction successfully recovered the complete attack sequence and decrypted the exfiltrated sensitive data, recovering the Showvault root token.

2. Incident Timeline

Time (UTC)	Component	Event Summary
18:02:10	npm / User	User BLACKMERE\mvale runs 'npm install' in repository fogline-showctl.
18:02:14	npm Mirror	Mirror serves trojanized pale-hash-utils@2.1.0 as transitive dependency of fetchling.
18:02:18	Node.js Process	postinstall script automatically triggers execution of node setup.js.

18:02:22	Network HTTP	setup.js makes HTTP GET for inter-var.woff2 to 203.0.113.77 carrying GA cookie seed.
18:02:25	Disk / Dropper	Payload decrypted from font file; writes C:\ProgramData\wt\wt.ps1.
18:02:27	PowerShell	wt.ps1 executed with bypass flags; setup.js self-deletes and renames package.md cover.
18:02:35	HTTP Proxy	wt.ps1 POSTs system telemetry via corporate proxy 10.40.0.8:3128 to C2 endpoint.
18:02:40	DNS Lookup	Queries DNS TXT record for cfg-6abd55d2.t.gravelantern.net to obtain key K.
18:02:50	Staging & Encrypt	Sensitive files zipped, encrypted with AES-256-CBC + HMAC-SHA256, custom Base32 encoded.
18:03:05	DNS Exfil	Base32 chunks transmitted via DNS A queries to *.t.mothwick-cdn.com (198.51.100.53).

3. Deep-Dive Attack Chain Analysis

Stage 1: Initial Access & Supply Chain Contamination

The initial compromise occurred on October 13, 2026, at approximately 18:02 UTC. User mvale initiated a standard build routine by running 'npm install' within the root of the project repository (C:\Users\mvale\source\repos\fogline-showctl). The project configured an internal mirror (npm-mirror.blackmere.lan:4873). The mirror pulled an unvetted package: pale-hash-utils@2.1.0. Notably, pale-hash-utils was not explicitly listed in fogline-showctl's package.json, but was resolved as a transitive dependency of fetchling.

The package's package.json contained an automated post-installation hook:

```
{
  "name": "pale-hash-utils",
  "version": "2.1.0",
  "scripts": {
    "postinstall": "node setup.js"
  }
}
```

Stage 2: Steganographic Payload Retrieval & Dropper (setup.js)

Upon completion of package download, Node.js automatically spawned 'node setup.js'. Analysis of the obfuscated setup.js script revealed the following execution steps:

1. Operating System Validation: Confirmed host operating system was Windows (win32).

2. Seed & Cookie Generation: Generated an 8-byte cryptographic random value and embedded it into a Google Analytics cookie header: _ga=GA1.1.<u32>.<u32>.

3. Steganographic Request: Issued an HTTP GET request to http://cdn.ossuary-assets.com/static/fonts/inter-var.woff2 (resolving to 203.0.113.77).

4. Key Derivation & Decryption: Derived an AES-256-CBC decryption key by concatenating a static seed with the generated random bytes: Key = SHA256('a6e217fb8de38593' || random_bytes). The Initialization Vector (IV) was extracted from bytes 4 through 20 of the downloaded font file. The decrypted payload was written directly to C:\ProgramData\wt\wt.ps1.

5. Execution & Anti-Forensics: Spawned PowerShell in a hidden window with ExecutionPolicy bypass, unlinked setup.js, and renamed package.md to package.json to remove installation anomalies.

```
powershell.exe -NoP -NonI -w hidden -ep bypass -File C:\ProgramData\wt\wt.ps1
```

Stage 3: Post-Exploitation & Dynamic Key Exchange (wt.ps1)

The secondary script C:\ProgramData\wt\wt.ps1 was encoded as a Base64 string compressed via Gzip. Once initialized in memory, it carried out two key operational objectives:

• Host Telemetry Exfiltration: Gathered system details (Hostname, Username, OS Version, PowerShell version, active AV status) and POSTed the JSON telemetry blob via the corporate proxy (10.40.0.8:3128) to http://cdn.ossuary-assets.com/api/v2/telemetry.

• Dynamic Key Negotiation: Retrieved host MachineGuid (bed3068c-ea38-419c-b94e-ab6d20d90816) and derived its MD5 prefix (6abd55d2). It then queried DNS TXT records for cfg-6abd55d2.t.gravelantern.net (fallback: .t.mothwick-cdn.com). The 16-byte session key 'K' was parsed from the TXT response under key 'p='.

Stage 4: Secrets Staging, Encryption & DNS Tunneling

With key K established, wt.ps1 scanned the local host and archived sensitive repositories and credential stores into a temporary ZIP file:

- fogline-showctl\.env (Containing Showvault root token)
- config\venues.json (Venue infrastructure configs)
- C:\Users\mvale\.npmrc (Internal mirror tokens)
- C:\Users\mvale\.ssh\known_hosts & .ssh\config
- C:\Users\mvale\.git-credentials (Git access tokens)

The script derived an encryption key kx = SHA256(K || MachineGuid) and encrypted the ZIP archive using AES-256-CBC with an appended HMAC-SHA256 signature. The resulting ciphertext was encoded using a custom Base32 alphabet and broken into 30-byte chunks.

Exfiltration occurred via DNS A queries. The leftmost labels of the queries carried encoded chunks to *.t.mothwick-cdn.com / *.t.pallbearer-metrics.io (resolving to 198.51.100.53). A final 'fin' packet transmitted the total chunk count and CRC verification hash before wt.ps1 deleted itself from the disk.

4. Token Extraction & Decryption Proof

To recover the exfiltrated secrets, forensic analysts extracted the ordered DNS A record queries from the network capture (NIC PCAP). Reconstructing the first ~20 Base32 chunks allowed partial AES-256-CBC payload decryption down to the raw Deflate stream of the embedded ZIP archive.

Decompressing the .env entry yielded the compromised Showvault root token:

```
SHOWVAULT_ROOT_TOKEN=forensic{8568b8444a7ac5335005c821}
SHOWVAULT_ENDPOINT=https://vault.internal.blackmere.lan:8200
SHOWVAULT_ROLE=root-master
```

5. Indicators of Compromise (IoCs)

Indicator Category	Indicator Value	Context / Description
Malicious Package	`pale-hash-utils@2.1.0`	Poisoned transitive dependency
File Artifact	`C:\ProgramData\wt\wt.ps1`	Dropped secondary stage script
File Artifact	`setup.js`	Steganographic downloader / postinstall script
IP Address	`203.0.113.77`	Stego font payload server (inter-var.woff2)
IP Address	`198.51.100.53`	DNS exfiltration target resolution IP
Internal Proxy	`10.40.0.8:3128`	Corporate proxy traversed by telemetry POSTs
C2 Domain	`cdn.ossuary-assets.com`	Telemetry and payload delivery domain
C2 DNS Zone	`*.t.gravelantern.net`	Dynamic key exchange TXT lookup zone
C2 DNS Zone	`*.t.mothwick-cdn.com`	Exfiltration DNS subdomains
Host Guid	`bed3068c-ea38-419c-b94e-ab6d20d90816`	Target workstation MachineGuid

6. Strategic Recommendations & Mitigation

- **npm Mirror Enforcement:** Configure strict package verification on npm-mirror.blackmere.lan. Block dynamic postinstall script execution during non-interactive developer builds by enforcing npm install --ignore-scripts in CI/CD and workstation environments.
- **DNS Anomaly Monitoring:** Deploy DNS logging and analytical rules to flag high-entropy subdomains, unusual query frequencies, and long hostnames targeting external domains. Block direct recursive external DNS resolution from workstations.
- **Secret Revocation & Rotation:** Immediately revoke and rotate the Showvault root token (forensic{8568b8444a7ac5335005c821}) and all git/SSH credentials residing on BLACKMERE\mvale.
- **Endpoint Detection & Response (EDR):** Configure endpoint policies to flag hidden PowerShell invocations launched from temporary directories (C:\ProgramData*) using bypass parameters (-ep bypass -w hidden).

Report Compiled by: Incident Response Team (BMH-IR)